Hermes Chat App

Ứng dụng nhắn tin bảo mật Desktop với trọng tâm là Mã hóa đầu cuối (E2EE).

Về Hermes

Bảo mật từ thiết bị của bạn

Hermes Chat App được xây dựng với mục tiêu cung cấp một nền tảng giao tiếp an toàn tuyệt đối. Mọi dữ liệu được bảo vệ ngay từ phần cứng cá nhân của bạn.

Dự án áp dụng các chuẩn mật mã học hiện đại như RSA, AES-GCM và cơ chế Key Wrapping (PBKDF2) để đảm bảo không một ai - kể cả quản trị viên hệ thống hay máy chủ - có thể giải mã và đọc được nội dung tin nhắn của bạn.

Core Feature

- **Triển khai bảo mật:** Tích hợp tính năng tự hủy tin nhắn sau một khoảng thời gian, kết hợp với mã hóa đầu cuối.
- **Cơ sở hạ tầng Auth an toàn:** Tích hợp Firebase Authentication cho Đăng ký, Đăng nhập và Khôi phục mật khẩu. Đảm bảo tính danh tính người dùng.
- **Bảo toàn dữ liệu (Rollback):** Tự động xóa user trên Firebase nếu quá trình khởi tạo khóa và lưu trữ xuống MySQL Server thất bại.

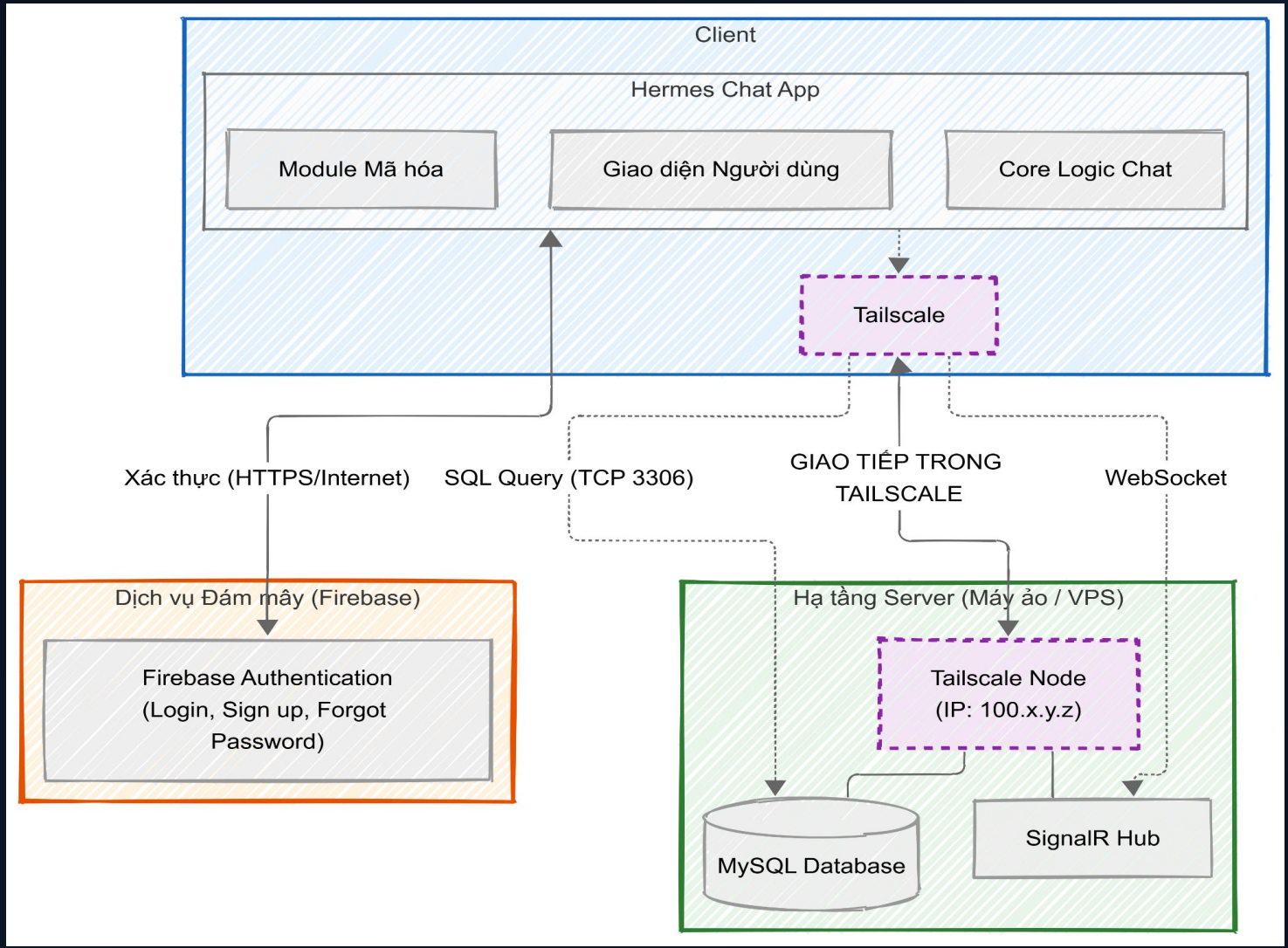
Mã hóa Hybrid (E2EE)

Bảo vệ tin nhắn thời gian thực

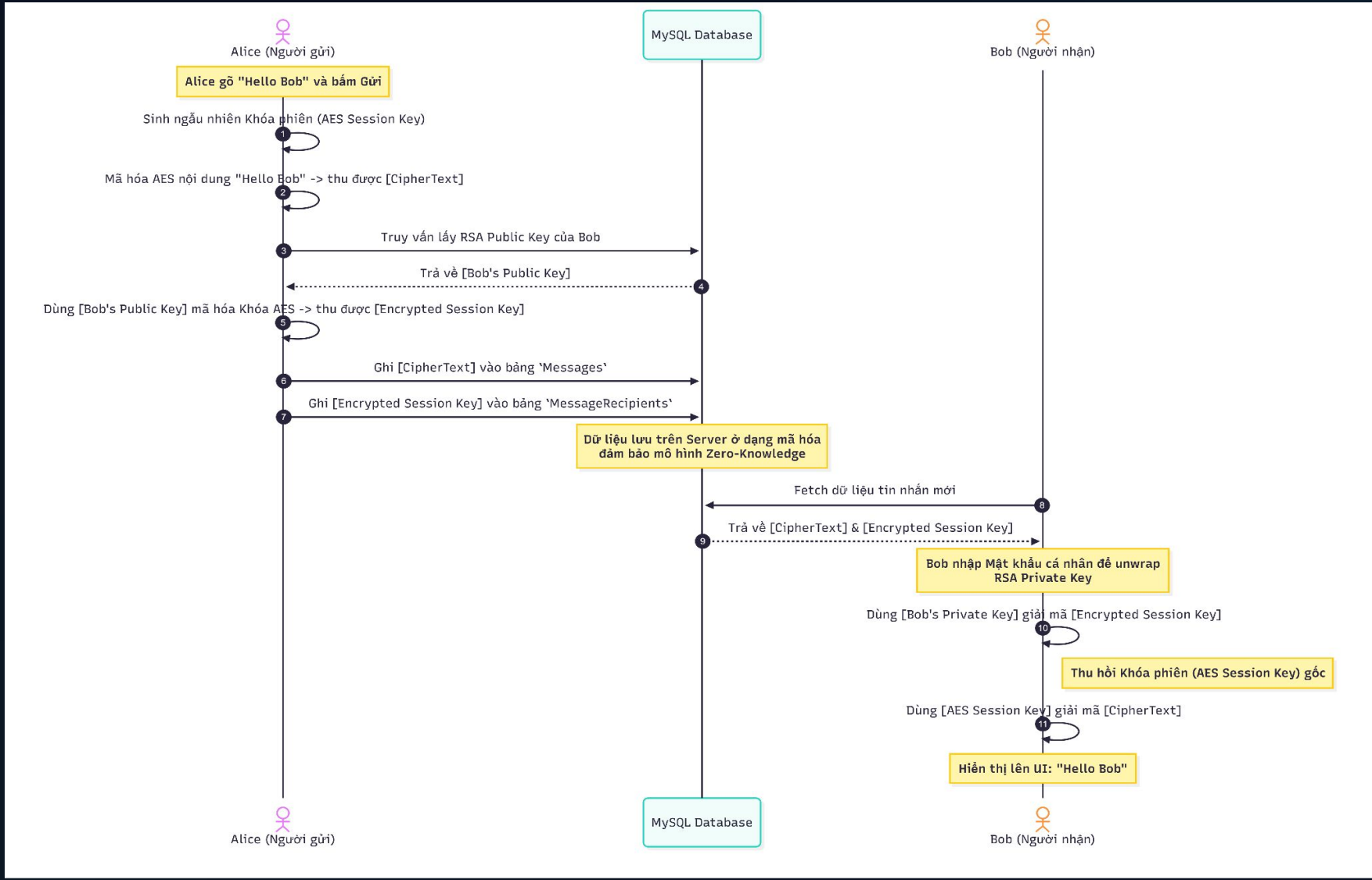
Hermes sử dụng mô hình mã hóa lai (Hybrid Encryption) để tối ưu cả hiệu suất và tính bảo mật cao nhất:

- **Thuật toán RSA (2048/4096-bit):** Sử dụng cặp Public/Private key để mã hóa và trao đổi khóa phiên một cách an toàn.
- **Thuật toán AES-GCM:** Được dùng để mã hóa trực tiếp nội dung tin nhắn, đảm bảo tốc độ cao và tính toàn vẹn của dữ liệu.
- **Key Wrapping (PBKDF2):** Private key được mã hóa bằng một Master Key (tạo ra từ Mật khẩu + Salt) trước khi đẩy lên CSDL.

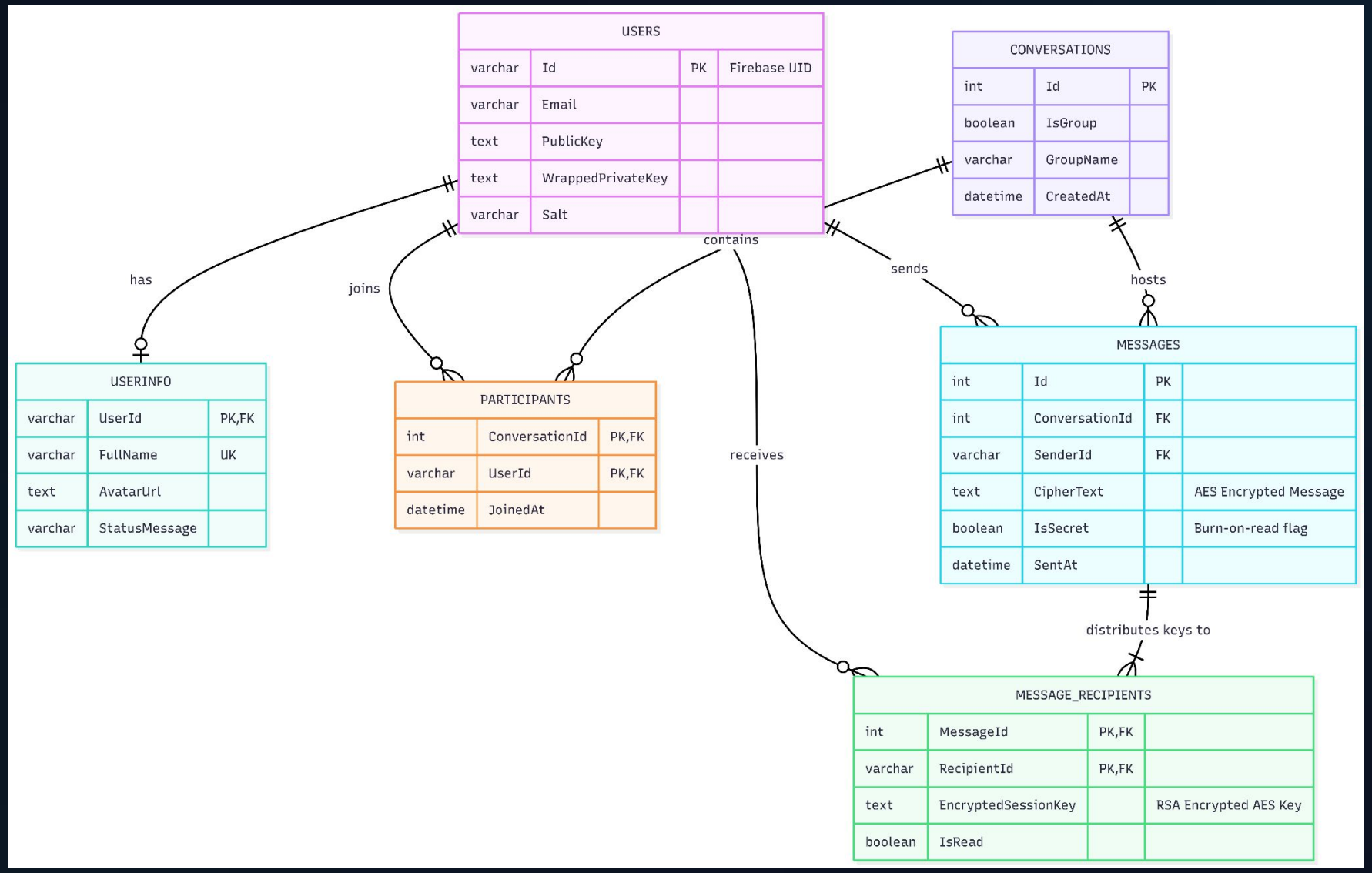
Kiến trúc Hệ thống



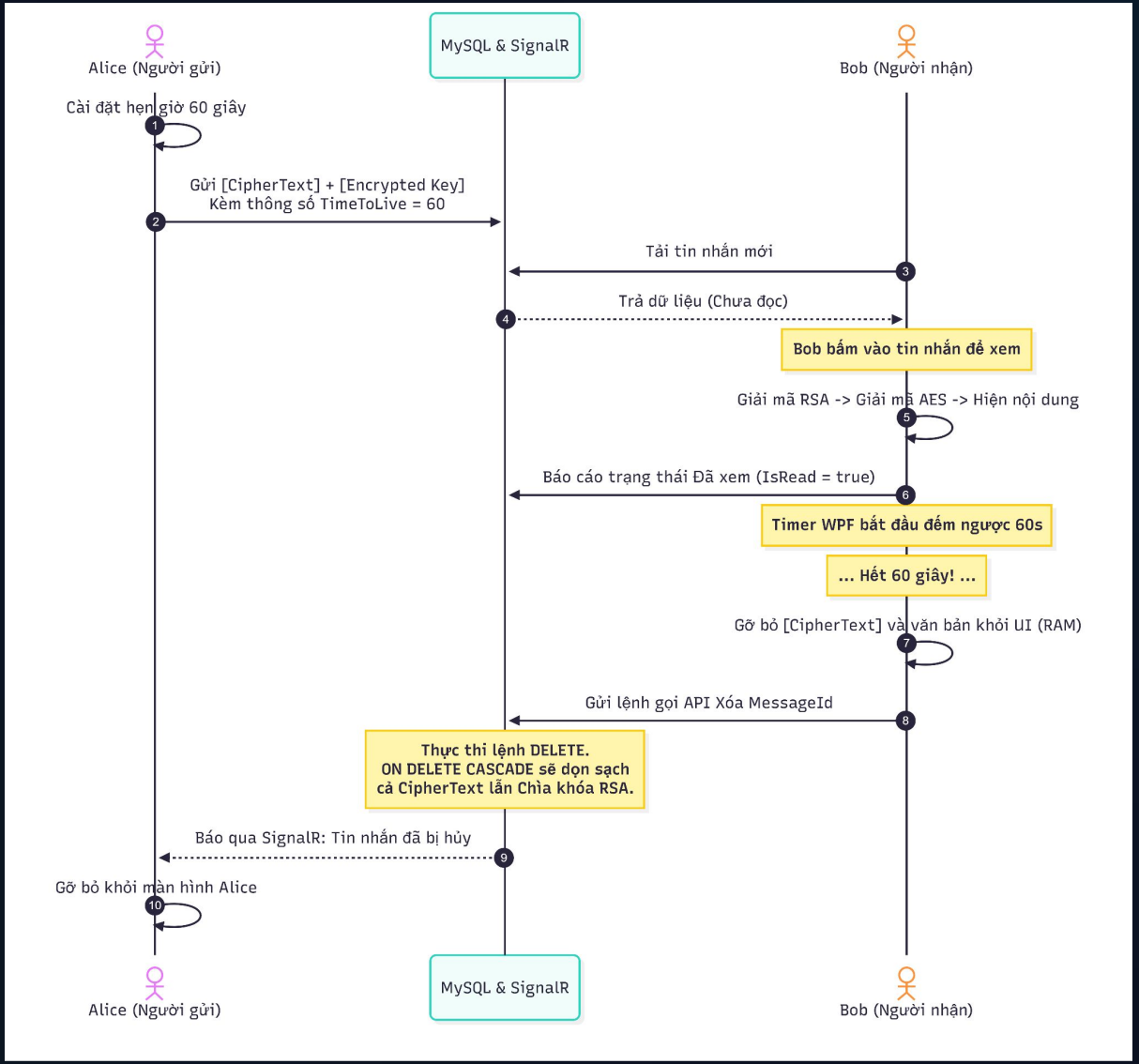
Luồng mã hóa


Alice (Người gửi)
MySQL Database
Bob (Người nhận)
Alice gõ "Hello Bob" và bấm Gửi
Sinh ngẫu nhiên Khóa phiên (AES Session Key)
1
Mã hóa AES nội dung "Hello Bob" -> thu được [CipherText]
2
Truy vấn lấy RSA Public Key của Bob
3
Trả về [Bob's Public Key]
4
Dùng [Bob's Public Key] mã hóa Khóa AES -> thu được [Encrypted Session Key]
5
Ghi [CipherText] vào bảng 'Messages'
6
Ghi [Encrypted Session Key] vào bảng 'MessageRecipients'
7
Dữ liệu lưu trên Server ở dạng mã hóa đảm bảo mô hình Zero-Knowledge
Fetch dữ liệu tin nhắn mới
8
Trả về [CipherText] & [Encrypted Session Key]
9
Bob nhập Mật khẩu cá nhân để unwrap RSA Private Key
Dùng [Bob's Private Key] giải mã [Encrypted Session Key]
10
Thu hồi Khóa phiên (AES Session Key) gốc
Dùng [AES Session Key] giải mã [CipherText]
11
Hiển thị lên UI: "Hello Bob"
Alice (Người gửi)
MySQL Database
Bob (Người nhận)

Database


USERS
varchar Id PK Firebase UID
varchar Email
text PublicKey
text WrappedPrivateKey
varchar Salt
CONVERSATIONS
int Id PK
boolean IsGroup
varchar GroupName
datetime CreatedAt
has
joins
contains
sends
hosts
receives
distributes keys to
USERINFO
varchar UserId PK,FK
varchar FullName UK
text AvatarUrl
varchar StatusMessage
PARTICIPANTS
int ConversationId PK,FK
varchar UserId PK,FK
datetime JoinedAt
MESSAGES
int Id PK
int ConversationId FK
varchar SenderId FK
text CipherText AES Encrypted Message
boolean IsSecret Burn-on-read flag
datetime SentAt
MESSAGE_RECIPIENTS
int MessageId PK,FK
varchar RecipientId PK,FK
text EncryptedSessionKey RSA Encrypted AES Key
boolean IsRead

Luồng tin nhắn tự hủy



Techstack

Front-end

Phát triển trên nền tảng **C# WPF** áp dụng mẫu thiết kế **MVVM** (Model-View-ViewModel) đảm bảo sự tách biệt logic và UI rõ ràng.

Back-end

Sử dụng **ASP.NET Core SignalR** để thiết lập kết nối WebSockets hai chiều, giúp tin nhắn được push theo thời gian thực.

Mật mã học

Thư viện System.Security.Cryptography gốc của .NET để triển khai thuật toán **RSA, AesGcm** và dẫn xuất khóa **Rfc2898DeriveBytes (PBKDF2)**.

Lộ trình Phát triển

Giai đoạn 1

Hoàn thiện UI cơ bản, tích hợp Firebase Auth và thiết kế Database Schema.

Giai đoạn 2

Deploy Tailscale VPN, thiết lập SignalR Hub và chức năng Chat Real-time.

Giai đoạn 3

Tích hợp Mật mã học và backend: Khởi tạo, Phân phối khóa RSA, Mã hóa AES Hybrid

Giai đoạn 4

Phát triển tính năng tin nhắn tự hủy

Trạng thái Công việc

Hạng mục	Nhiệm vụ chi tiết	Trạng thái
Giao diện & Auth	Tích hợp Firebase Auth, Tự động Rollback, UI Đăng nhập	Completed
Hạ tầng Server	Dựng Remote Server qua Tailscale VPN, Setup MySQL	Completed
Core Chat Logic	Thiết lập SignalR Hub, tin nhắn Real-time	In Progress
Bảo mật E2EE	Khởi tạo RSA, Mã hóa AES Hybrid, Key Wrapping	In Progress
Tin nhắn tự hủy	Thiết lập thời gian tự hủy của tin nhắn, tính năng tự hủy	Not Started